

Plantilla de Excel para Cálculo de IGM y ROI de Ciberseguridad

Basado en la Encuesta AMPARO-ENS

Esta plantilla está pensada para implementarse en Excel (o herramienta equivalente), a partir de las respuestas a la encuesta.

1. Estructura de hojas

Se recomienda crear, al menos, las siguientes hojas:

1. Diccionario – catálogo de preguntas, códigos y pesos.
2. Respuestas – matriz de respuestas de cada organización.
3. IGM – cálculo del Índice Global de Madurez y subíndices.
4. ROI – estimaciones de retorno de inversión de ciberseguridad.
5. Resumen – tablas y gráficos de resultados.

2. Hoja Diccionario

Columnas sugeridas:

- CODIGO – Identificador de la pregunta (ej. GOB_1_1, RISK_2_2).
- BLOQUE – Gobierno, Riesgo, Operación, Recursos, Cultura, Métricas.
- DESCRIPCION_PREGUNTA – Resumen de la pregunta.
- TIPO – Binaria / Ordinal / Nominal / Abierta.
- VALOR_MIN – Valor mínimo (normalizado).
- VALOR_MAX – Valor máximo (normalizado).
- PESO_IGM – Peso relativo de la pregunta en el IGM (0–1).
- PESO_SUBINDICE – Peso en el subíndice del bloque.
- REFERENCIA_ENS – Artículo / Anexo / Guía CCN-STIC asociada.

Ejemplo de filas:

- GOB_1_1 – Política de seguridad aprobada – Tipo: Ordinal – VALOR_MIN=0; VALOR_MAX=3; PESO_IGM=0,02.
- RISK_2_1 – Metodología de análisis de riesgos – Ordinal – VALOR_MIN=0; VALOR_MAX=3; PESO_IGM=0,03.
- INC_3_3 – MTTD/MTTR medidos – Binaria/Ordinal – VALOR_MIN=0; VALOR_MAX=2; PESO_IGM=0,03.

La suma de PESO_IGM de las preguntas seleccionadas debe ser 1.

3. Hoja Respuestas

Cada fila representará una organización. Las columnas incluirán:

- ORG_ID – Identificador (anónimo) de la organización.
- TIPO_ENTIDAD, TAMANO, SECTOR, etc. (metadatos).
- Una columna por cada CODIGO de pregunta, con la respuesta ya codificada numéricamente.

Ejemplo de codificación:

- GOB_1_1: 0 = No existe política; 1 = En elaboración; 2 = Aprobada, desactualizada; 3 = Aprobada, vigente.
- ZT_2_2 (MFA): 0 = No se usa; 1 = uso parcial; 2 = alta cobertura; 3 = 100 % accesos críticos.

4. Hoja IGM

4.1. Normalización de respuestas

Para cada pregunta incluida en el IGM:

- Calcular VALOR_NORMALIZADO = (RESPUESTA - VALOR_MIN) / (VALOR_MAX - VALOR_MIN).
- El resultado estará entre 0 y 1.

En Excel, por ejemplo, si VALOR_MIN está en Diccionario!E2, VALOR_MAX en Diccionario!F2, y la respuesta de la organización en Respuestas!C2, la fórmula sería:

```
= (Respuestas!C2 - Diccionario!E2) / (Diccionario!F2 - Diccionario!E2)
```

4.2. Cálculo de subíndices

Para cada bloque (Gobierno, Riesgo, Operación, etc.):

- SUBINDICE_BLOQUE = SUMA(VALOR_NORMALIZADO_i * PESO_SUBINDICE_i)
donde i recorre las preguntas de ese bloque.

En Excel, puede hacerse con una combinación de SUMAPRODUCTO filtrando por bloque o mediante columnas auxiliares.

4.3. Cálculo del IGM (Índice Global de Madurez)

- IGM = 100 * SUMA(VALOR_NORMALIZADO_i * PESO_IGM_i)

Esto da un resultado entre 0 y 100. Se puede representar en:

- Escala cualitativa:
- 0–39: Nivel inicial
- 40–59: Nivel básico
- 60–79: Nivel intermedio
- 80–100: Nivel avanzado

5. Hoja ROI

El cálculo de ROI se apoyará en:

6. Costes de ciberseguridad (anuales)
7. COSTE_CONTROLES – presupuesto en controles (MFA, SIEM, BCP, etc.).
8. COSTE_PERSONAL – salarios y cargas de personal de ciberseguridad.
9.
COSTE_AUDITORIA – ENS, ISO, otros.
10.
Costes de incidentes (anuales estimados)
11. NUM_INCIDENTES – número de incidentes relevantes.
12. COSTE_MEDIO_INCIDENTE – coste estimado (parada, remedio, reputación).
13.
$$\text{COSTE_INCIDENTES} = \text{NUM_INCIDENTES} * \text{COSTE_MEDIO_INCIDENTE}.$$
14.
Escenarios de mejora

COSTE_AUDITORIA – ENS, ISO, otros.

Costes de incidentes (anuales estimados)

$$\text{COSTE_INCIDENTES} = \text{NUM_INCIDENTES} * \text{COSTE_MEDIO_INCIDENTE}.$$

Escenarios de mejora

Se puede definir:

- IGM_ACTUAL – a partir de la hoja IGM.
- IGM_OBJETIVO – objetivo a 2–3 años.
- Supuesto: un incremento de IGM (por ejemplo, +10 puntos) se asocia a una reducción porcentual de COSTE_INCIDENTES (por ejemplo, 20–30 %, a definir según sector y experiencia).

Fórmulas posibles:

- $COSTE_INCIDENTES_ACTUAL$
- $COSTE_INCIDENTES_FUTURO = COSTE_INCIDENTES_ACTUAL * (1 - REDUCCION_POR_IGM)$
- $INVERSION_MEJORA = COSTE_ADICIONAL_CONTROLES + COSTE_ADICIONAL_PERSONAL.$
- $AHORRO_ESPERADO = COSTE_INCIDENTES_ACTUAL - COSTE_INCIDENTES_FUTURO.$
- $ROI = (AHORRO_ESPERADO - INVERSION_MEJORA) / INVERSION_MEJORA.$

$COSTE_INCIDENTES_FUTURO = COSTE_INCIDENTES_ACTUAL * (1 - REDUCCION_POR_IGM)$

$INVERSION_MEJORA = COSTE_ADICIONAL_CONTROLES + COSTE_ADICIONAL_PERSONAL.$

$AHORRO_ESPERADO = COSTE_INCIDENTES_ACTUAL - COSTE_INCIDENTES_FUTURO.$

$ROI = (AHORRO_ESPERADO - INVERSION_MEJORA) / INVERSION_MEJORA.$

La plantilla puede parametrizar REDUCCION_POR_IGM (por ejemplo, 0,2; 0,3), y analizar escenarios optimista, conservador y pesimista.

6. Hoja Resumen

Incluir, al menos:

- Tabla con IGM por organización, tipo de entidad y sector.
- Gráficos de barras o radar por subíndices (Gobierno, Riesgo, Operación, Recursos, Cultura, Métricas).
- Tabla con ROI estimado por escenario de inversión.
- Indicadores de dispersión (mínimo, máximo, mediana, cuartiles).

7. Notas metodológicas

- Es importante documentar, en la propia hoja, las hipótesis utilizadas para el cálculo de ROI (porcentajes de reducción de incidentes, costes medios, etc.).
- Para análisis nacionales o sectoriales, se recomienda trabajar con datos anonimizados y agrupar por categoría (administración central, autonómica, local, proveedores, etc.).
- El IGM no sustituye las métricas ENS oficiales, pero ofrece una visión sintética útil para diálogo estratégico y benchmarking.

Con esta plantilla, la encuesta AMPARO-ENS se convierte en algo más que un conjunto de respuestas: en un instrumento cuantitativo para hablar de madurez, riesgo y dinero con un mínimo de rigor y un máximo de claridad.